TaskFlow Software – Phishing Incident Response Playbook

Playbook ID: IR-PB-001
Incident Type: Phishing Attack
Severity: High (Critical if account compromise is confirmed)
Primary Owner: SOC Analyst
Environment: TaskFlow Software SaaS Beta
Status: Draft – Pending Tabletop Validation

1. Purpose

This playbook defines the steps for detecting, investigating, containing, and recovering from phishing incidents affecting TaskFlow Software.

The objective is to prevent unauthorized access, protect customer information, and reduce business disruption.

2. Affected Assets

Asset ID	Asset Name	Risk Level
TF-004	Authentication Service	Critical
TF-003	Customer Database	Critical
TF-001	Web Application	Critical
TF-007	Logging and Monitoring System	High

Primary risk: Attackers may steal employee credentials and gain unauthorized access to TaskFlow systems.

3. Detection and Identification

Responsible: SOC Analyst

1. Review phishing-related alerts in Elastic Security/Kibana.
2. Examine suspicious email indicators, including sender, links, attachments, and timestamps.
3. Check authentication logs for unusual login attempts involving the targeted account.
4. Correlate source IP addresses, usernames, and event timestamps.
5. Determine whether the phishing attempt resulted in credential theft or unauthorized access.
6. Preserve relevant alert IDs, email evidence, and authentication logs.

Detection source: Phishing Sigma rule and Elastic Security alerts.

4. Incident Response Procedures

Phase 1 – Preparation

Responsible: SOC Analyst

- Confirm access to Elastic Security and the incident response documentation.
- Identify critical assets using `assets.json`.
- Confirm escalation contacts and approved account-containment procedures.

Phase 2 – Analysis and Classification

Responsible: SOC Analyst

- Review email indicators and associated authentication activity.
- Identify affected accounts and potentially exposed systems.
- Classify the incident as suspicious, attempted phishing, or confirmed compromise.
- Escalate confirmed account compromise as a critical incident.

Phase 3 – Containment

Responsible: SOC Analyst / System Administrator

- Request temporary suspension of confirmed compromised accounts.
- Revoke active sessions and authentication tokens where supported.
- Block verified malicious domains or indicators using approved security controls.
- Notify affected users and relevant system owners.
- Preserve evidence before making changes where feasible.

Phase 4 – Eradication

Responsible: System Administrator

- Remove confirmed malicious messages from affected mailboxes where supported.
- Reset compromised credentials through a trusted process.
- Revoke unauthorized application permissions and access tokens.
- Check for malicious persistence or unauthorized account changes.

Phase 5 – Recovery

Responsible: System Administrator / SOC Analyst

- Restore access after identity verification and credential remediation.
- Require MFA where supported.
- Monitor authentication logs for renewed suspicious activity.
- Verify affected accounts and services are operating normally.
- Document recovery evidence and obtain closure approval.

Phase 6 – Lessons Learned

Responsible: SOC Analyst

- Record the incident timeline and response decisions.
- Identify detection gaps and response delays.
- Recommend phishing awareness training and improved alert correlation.
- Update the playbook based on tabletop exercise findings.

5. Escalation and Responsibilities

Role	Responsibility
SOC Analyst	Detect, investigate, document, and coordinate response
System Administrator	Disable accounts, revoke sessions, and restore access
Management / Incident Owner	Approve high-impact actions and incident closure
Affected User	Report suspicious activity and follow account recovery instructions

For TaskFlow's single-analyst environment, the SOC Analyst coordinates escalation to the appropriate authorized personnel.

6. Closure Criteria

The incident may be closed when:

- Affected accounts have been investigated and secured.
- Confirmed malicious access has been removed.
- Relevant evidence and actions have been documented.
- Authentication monitoring shows no continuing related suspicious activity.
- The incident owner has approved closure.

References: `assets.json`, TaskFlow phishing detection rule, Elastic Security dashboard.

Note: This playbook documents proposed response procedures. Operational execution and effectiveness will be evaluated during the tabletop exercise.